

CYBERSECURITY RESEARCH PRESENTATION

AI-Enhanced Attacks on Cloud Infrastructure

How AI is accelerating attacks and reshaping identity risk in cloud security

Faculty of Science and Technology
University of the Thai Chamber of Commerce

Presented by
Jarudech Thongkum · 2310511101112 · 25 August 2026



UTCC | STECH

คณะวิทยาศาสตร์และเทคโนโลยี

72

H O U R S

Compromised npm package → **AWS Administrator**

No zero-day required.

No new hacking technique. The difference is that AI carried out part of the work in between — the part a human used to do by hand.

Four parts

01

The Problem

How cloud threats are changing

02

The Theory

Why identity, AI, and speed matter

03

Case Study

UNC6426

04

Future Work

From literature review to a testable prototype

METHODOLOGY

Literature Review

Primary industry reports, compared against one another.

1

Original industry reports

Read directly from the publishing organisation, not through news coverage or vendor summaries.

2

Cross-source comparison

Each claim checked against at least one independent dataset before it is used.

3

Recent 2026 publications

Every source published in 2026, so the picture reflects the current state.

MAIN SOURCES

Cloud Security Alliance · Google Cloud Threat Intelligence · Verizon DBIR · OWASP GenAI Security Project

Cloud threats are changing

CSA Top Threats to Cloud Computing 2026 — published 13 August 2026

#1	Inadequate Identity and Access Management	▲ from #2
#2	AI-Enhanced Attacks	★ NEW
#5	Misconfiguration & Change Control	▼ from #1
#6	AI System Compromise	★ NEW

Two AI-related threats entered the ranking for the first time — **one of them straight into second place.**

Three changes behind that ranking

01

**AI is already
a current threat**

Not a forecast. It entered the top threats this year, as both a tool for attackers and a target to defend.

02

**Automation is reducing
traditional
misconfiguration**

CSPM and pipeline guardrails now catch insecure settings before they reach production.

03

**Identity is becoming
more important**

As configuration comes under control, access itself becomes the thing worth attacking.

These three move together: solving the old problem is what made the new one visible.

Initial access is changing



≈ 15×

Software vulnerability exploitation went from 2.9% to 44.5% of initial access in one half-year.

What it means

Every other route declined. Attackers are not more numerous — they are faster at turning a public disclosure into a working exploit.

Speed becomes a security problem

Weeks → **Days**

Time from vulnerability disclosure to exploitation in the wild

≈ 48 hours

React2Shell (CVE-2025-55182) — disclosure to confirmed exploitation

Human-only response may be too slow

As exploitation windows shrink from weeks to days, defenders have less time to detect, assess, and patch critical vulnerabilities.

Faster attacks require faster defense.

Automated detection, virtual patching, and rapid remediation can help defenders respond within this shrinking window.

Cross-source validation

Two datasets collected separately — do they point the same way?

	Google Cloud	Verizon DBIR (Data Breach Investigation Report)	
Vulnerability exploitation	↑ rising	↑ rising	AGREE
Credential abuse	↓ falling	↓ falling	AGREE
Third-party involvement	21%	48%	DIFFER

Different datasets. Similar direction.

Google observes cloud environments; Verizon observes breaches across all sectors. The absolute numbers should differ — what matters is that the trend is the same in both.

Sources: Google Cloud Threat Horizons H1 2026; Verizon 2026 Data Breach Investigations Report

Three concepts explain the change

1

Shared Responsibility

Who is accountable for what once the infrastructure moves to the cloud

2

Identity

What actually defines the boundary now that the network no longer does

3

AI: Weapon & Target

Two different security problems that happen to share a name

Cloud Security 2026

Everything in the case study that follows is an instance of one of these three.

Concept 1 - Shared Responsibility

Moving to the cloud moves the infrastructure — not the responsibility.



Security OF the Cloud

Provider

- Physical data centres
- Hardware and hypervisor
- Core network infrastructure



Security IN the Cloud

Customer

- Identity and access management
- Configuration of every service
- Data, encryption, and secrets

Every step of the case study in Part 3 happened on the customer side. The provider was never breached.

Concept 2 · Identity as a security boundary

≈ 45 : 1

Non-human identities outnumber human ones — and AI agents are pushing that ratio further.

Non-Human Identities

Service accounts

API keys

OAuth tokens

CI/CD Service Account /
Workload Identity

AI agents

Container workloads

Most have no MFA, no key rotation, and no periodic access review.

83% of cloud compromises had an identity problem at their root — which is why Inadequate IAM is now the number one threat.

Concept 3a · AI as a weapon

CSA rank #2 — AI-Enhanced Attacks

1

Reconnaissance

Mapping a target environment at machine speed instead of by hand.

2

Credential discovery

Sweeping a filesystem for keys, tokens, and secrets automatically.

3

Social engineering at scale

Vishing 17% and phishing 12% of compromises — quality no longer limits volume.

4

Faster attack workflow

Less waiting between steps, so the whole chain completes before anyone reacts.

AI-Enhanced Attack: the techniques are familiar. What changed is how little time passes between them.

Concept 3b · AI as a target

CSA rank #6 — AI System Compromise

AI SYSTEM ATTACK SURFACE

Model

Training Data

Vector DB

System Prompt

API Keys

AI Agent

AI Agent = **Identity** + **Permission** + **Action**

An agent is not a passive asset like a database. Compromising it does not leak data — it hands the attacker a legitimate operator inside the environment.

OWASP reached the same conclusion independently: its 2026 GenAI Top 10 moved "Excessive Agency" up, shifting the advice from hardening inputs to limiting what an agent can reach when it is fooled.

Defence principles

Each one follows from a concept above.

1 Identity

- MFA — phishing-resistant, FIDO2 or passkeys
- Least Privilege — only what the task needs
- Scoped Trust — narrow OIDC and OAuth scopes

2 Speed

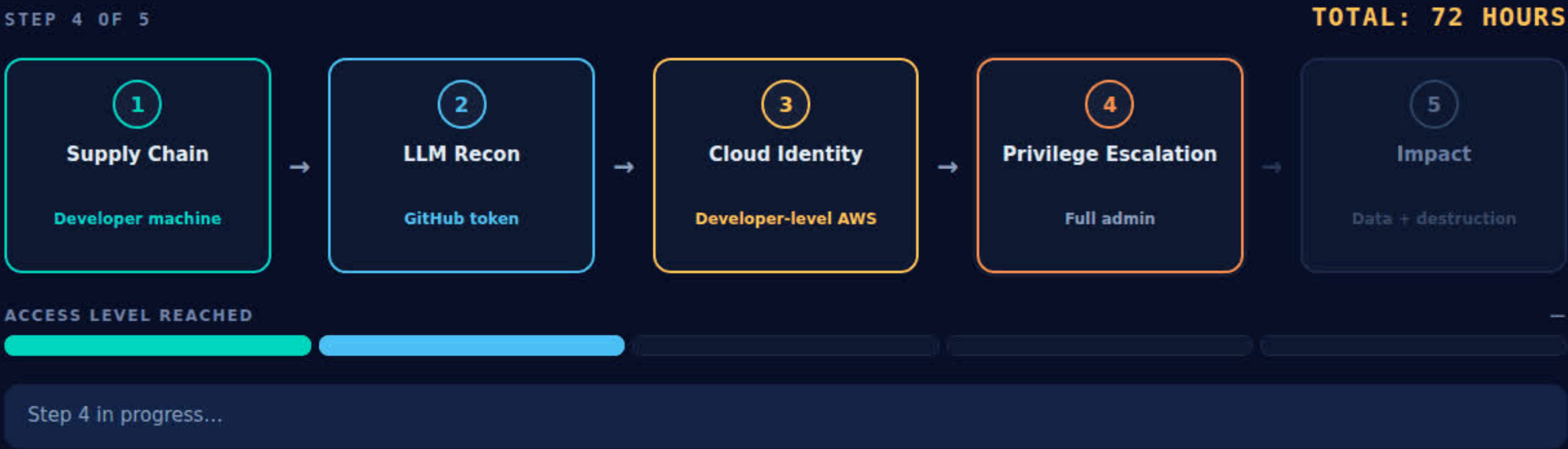
- Detection at machine speed
- Patch within days, not months
- Automation answering automation

3 AI Governance

- Inventory — know what AI is running
- Logging — treat model calls like admin commands
- Permissions — limit what an agent can reach

The goal is not to make compromise impossible. It is to make sure that one compromised identity does not become total access.

UNC6426 — a 72-hour attack chain



Sequence, techniques and total elapsed time reported in Google Cloud, Cloud Threat Horizons Report H1 2026. Per-step timings are not published; the ordering shown is the reported sequence, not a measured timeline.

Only one of these five steps involves AI. Every other technique has existed for years — and because each step builds on the one before it, breaking any single step breaks the chain.

Source: Google Cloud, Cloud Threat Horizons Report H1 2026

Supply Chain



The victim did nothing wrong

No phishing email. No stolen password. A developer installed a dependency the way they do every day, and a postinstall script ran the malware automatically.

Concept it demonstrates: insecure third-party resources — CSA threat #3.

AI-Assisted Reconnaissance

LLM-assisted discovery

The malware prompted a language model to sweep the filesystem, instead of an operator doing it by hand.

`.env`

`.conf`

`.log`

`.bak`



Credentials · Tokens · Secrets

This is the one AI step. Work that took a skilled operator hours now finishes in seconds
— that is the entire contribution of AI to this attack.

Identity Bridge to AWS

Before entering AWS



The attacker never touched an AWS password

OIDC trust exists so a pipeline does not have to store long-lived AWS keys — it is the more secure design. But the trust was scoped too broadly, so stealing the GitHub token was enough to inherit access to the cloud account.

Concept it demonstrates: non-human identity and inadequate IAM — CSA threat #1.

Privilege Escalation

After entering AWS

Developer
Permission



CloudFormation



AdministratorAccess

Living-off-the-Land

CloudFormation is a normal deployment tool. Using it to attach an admin policy means the action appears in the audit log as an ordinary deployment — no malware, nothing obviously out of place.

Concept it demonstrates: a failure of least privilege — the pipeline role should never have been able to modify IAM.

Impact

S3 Discovery

Amazon Simple Storage Service

Enumerated every storage bucket in the account

EC2 / RDS Destruction

Elastic Compute Cloud /
Relational Database Service

Terminated the servers and databases running the business

Source Code Exfiltration

Copied repositories out of the environment

AI did not invent the attack.

It accelerated part of an existing attack chain.

Case → Theory

Each phase is an instance of something from Part 2 — nothing in this chain is exotic.

Phase 1	Supply Chain	→	Third-party risk
Phase 2	LLM Recon	→	AI-enhanced attack
Phase 3	OIDC / STS	→	Identity
Phase 4	Privilege Escalation	→	Least privilege
Phase 5	Cloud Impact	→	Shared responsibility
Each phase maps to a known security control, showing where the attack chain could potentially be disrupted.			

What this study cannot answer

Stating the boundaries is part of the analysis, not a weakness in it.

Secondary data

Every figure comes from a publisher. None of it was collected or verified by me.

Different datasets

Each organisation measures a different population, so numbers are not directly comparable.

One case study

UNC6426 illustrates the pattern, but one intrusion cannot establish how common it is.

No controlled experiment

Nothing here tests which control actually stops an attack, or by how much.

So this study can describe trends and explain patterns — **but it cannot yet show, from my own evidence, how much a given control actually helps.**

Research gap

How does IAM permission scope affect the blast radius of a compromised cloud identity?

Literature

What the reports say happens



Controlled Experiment

What I can measure myself

Deliberately narrow: rather than reproducing the whole UNC6426 chain, isolate one key factor
IAM permission scope and measure its effect on blast radius.

Proposed MVP prototype

Minimum Viable Product

RQ — How does IAM permission scope affect the **blast radius** of a compromised cloud identity?

One compromised identity · one fixed action set · three IAM policies

Illustrative — experiment not yet run

THE FIXED INPUT	compromised identity	READ s3:GetObject	WRITE s3:PutObject	DESTROY ec2:TerminateInstances	ESCALATE iam:CreateRole / AttachPolicy	15 actions per run
WHAT IS MEASURED	Policy A over-permissive	Policy B moderate	Policy C least privilege			
Actions the identity completed	? / 15	? / 15	? / 15			
Distinct resources reached	?	?	?			
Destructive action possible?	yes / no	yes / no	yes / no			
Escalation to administrator?	yes / no	yes / no	yes / no			
CLOUDTRAIL — THE MEASURING INSTRUMENT						recording · 3 of 3 runs
policy A eventName TerminateInstances errorCode — → counted as completed						
policy B eventName TerminateInstances errorCode AccessDenied → counted as blocked						
policy C eventName CreateRole errorCode AccessDenied → counted as blocked						
Every attempt is logged with eventName and errorCode — so “what the attacker could do” becomes a count , not a claim.						

These four rows are the result of the project. **They are empty today — filling them is the work.**

Proposed method. Command syntax and CloudTrail fields are real AWS behaviour; every result cell is deliberately empty because the experiment has not been run.

Anchored in the case — Google reports the compromised Github-Actions-CloudFormation role was “**overly permissive**”. This experiment measures what that word costs.

Prototype scope

Two levels, so the project does not depend on building a large cloud system first.

MVP — Required

Prove the core concept first.

IAM Policies

S3 + EC2

Fixed Action Set

CloudTrail

Extension

Move the experiment closer to the real case.

OIDC trust

CI/CD identity

Network segmentation

Automated detection

Start small → extend gradually. The project does not depend on finishing a large cloud environment before it can produce a result.

Future expansion

Phase 1

IAM Blast-Radius Experiment

Measure the effect of permission scope using fixed action set.

Phase 2

OIDC / CI-CD Identity

Move the setup closer to the real UNC6426 chain.

Phase 3

Detection & Automated Response

Test whether suspicious activity can be detected and contained.

Future

AI-assisted log analysis & investigation

Use AI to help analyze cloud logs and investigate suspicious activity faster.

The first prototype does not have to answer everything. It has to be a starting point that can be extended.

CONCLUSION

Three things to take away

01

AI changes speed

It compresses the time between existing attack steps, so defence that waits for a human is already behind.

02

Identity defines access

With the network no longer the boundary, a compromised identity is the compromise.

03

Defence must limit impact

The goal is not preventing every compromise — it is making sure one does not become total access.

Start with identity. Build from there.

REFERENCES

Sources

1

Cloud Security Alliance

[Top Threats to Cloud Computing 2026](#) — Published 13 August 2026 — survey of 500+ security professionals.

2

Google Cloud Threat Intelligence

[Cloud Threat Horizons Report H1 2026](#) — Initial access vectors, identity statistics, and the UNC6426 analysis.

3

Verizon Business

[2026 Data Breach Investigations Report](#) — Independent corroboration of the access-vector shift.

4

OWASP GenAI Security Project

[LLM Top 10 2026](#) · [Agentic Application Top 10 2026](#) — Excessive agency and containment-first agent security.

Thank you · Questions?